

Uncertainty-Routed 3-Tier WAF

Sami Bou Khaled
Student ID: 202303124

CSC 437 – Network Security
Instructor: Dr. Khaleel Mershad
May 3, 2026

1 Introduction

Modern web application firewalls still face the same practical tradeoff: deterministic signatures are fast and precise for known patterns, but real traffic mixes benign variation, evasive payloads, and previously unseen attack shapes. This project addresses that gap with a three-tier web application firewall (WAF) that routes requests by confidence instead of forcing a single detector to solve every case. Tier 1 applies regex rules, Tier 2 uses a calibrated character-level LSTM for coarse allow/block decisions, and Tier 3 invokes a specialist model only on the uncertain slice.

The project objective is not only detection accuracy, but also operational discipline. The system separates cheap deterministic matches from learned decisions, calibrates routing thresholds explicitly, exposes profile-controlled runtime policy, and feeds confident Tier 3 blocks back into a regex-synthesis loop. That framing is important for deployment: a security system that cannot explain its routing policy, control false positives, or evolve repeatable signatures is difficult to trust even if its raw classifier scores appear strong.

This report therefore evaluates the project from two angles. First, it documents the final specialist-era architecture and the codebase cleanup that made the implementation easier to validate and maintain. Second, it positions the system relative to recent work on web-request classification, anomaly detection, transformer-based HTTP analysis, and machine-learning-assisted firewall automation.

2 State of the Art

Recent literature on anomaly detection shows a clear movement away from single handcrafted signatures toward hybrid systems that combine representation learning, calibrated decision rules, and domain-specific traffic features. Broad surveys such as the deep anomaly-detection review in [14] describe the strengths of learned latent representations, but they also emphasize a persistent deployment problem: many anomaly detectors remain difficult to calibrate and prone to domain drift. That observation directly motivates a cascade architecture rather than a monolithic “anomaly-only” WAF.

One line of work targets malicious web requests directly. Transformer and contrastive-learning approaches for unsupervised request detection [6], deep-learning WAFs for XSS or SQL injection [13, 8, 12, 2], and broader HTTP anomaly detectors in IDS settings [10, 7, 11] all improve on rule-only baselines by learning content patterns that signatures miss. However, most of these systems still optimize a single model as the main decision surface. In contrast, this project deliberately

constrains the learned models to different roles: Tier 2 resolves the majority of traffic, while Tier 3 specializes only on the residual uncertain band.

Another line of work studies richer contextual inputs and more flexible learning machinery. LLM-guided unknown-web-attack detection [18], NLP-driven intrusion detection [5], zero-trust HTTP anomaly detection [10], and machine-learning-enhanced firewalls [1, 15, 4] all argue that web security benefits from request semantics beyond simple tokens or regex matches. This project aligns with that trend, but uses the richer representation in a narrower way: the specialist model is trained only on the traffic region that Tier 2 cannot confidently classify. That choice reduces hot-path cost and makes the expensive model answer a better-scoped question.

Several papers also explore automation around firewall management, threat intelligence, and adaptive response [3, 16, 19, 9]. Those systems are relevant because they move from pure classification toward operator assistance and policy adaptation. The regex-synthesis stage in this project fits that category: repeated confident Tier 3 blocks can become deterministic Tier 1 rules, which turns a previously expensive pattern into a cheap early exit. That feedback loop is smaller in scope than a full threat-intelligence platform, but it is operationally useful and directly tied to runtime observations.

Finally, the literature makes clear that there is no single best model family for every security setting. Classical one-class methods still appear in web anomaly detection [11]; recurrent models remain competitive for compact HTTP surfaces [13, 4]; transformer-based and contrastive methods offer stronger unsupervised expressiveness [6]; and broader cybersecurity studies continue to examine anomaly detection in adjacent domains such as IoT or 5G [9, 17]. The design choice here is therefore pragmatic: keep Tier 2 simple, calibrated, and fast; make Tier 3 specialist and abstention-aware; and route between them with explicit thresholds instead of relying on one large model to behave well across every regime.

3 Design and Implementation

3.1 System Design

Figure 1 shows the final runtime architecture. Requests first pass through Tier 1 regex rules. Non-matching traffic is evaluated by the calibrated Tier 2 character LSTM. Requests outside the uncertain band are resolved immediately, while uncertain requests escalate to the Tier 3 specialist. If Tier 3 blocks a request with sufficiently strong evidence, the system may synthesize a candidate regex rule for future Tier 1 use.

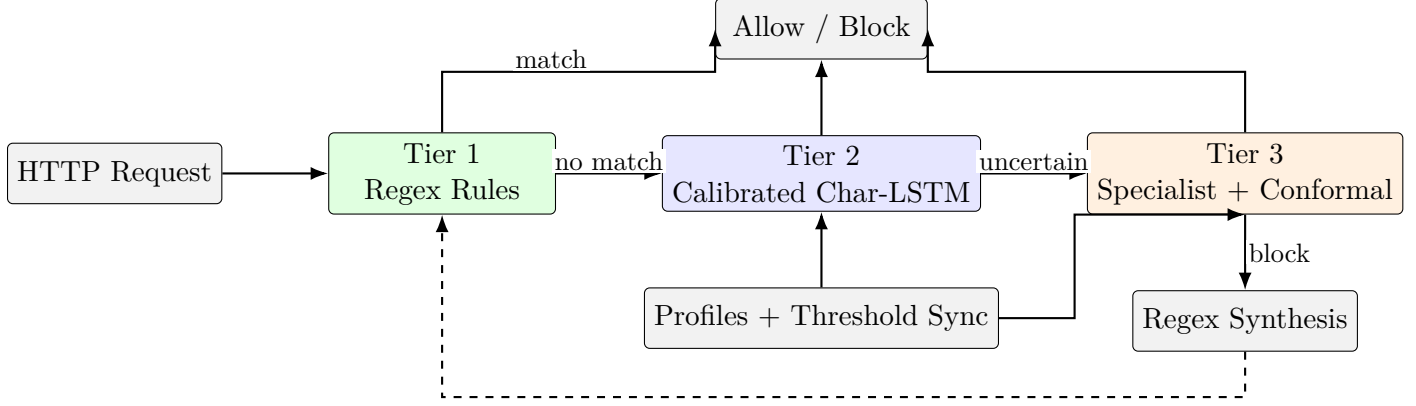


Figure 1: Runtime architecture of the uncertainty-routed WAF.

Two details are central to the design. First, the runtime policy is profile-driven rather than hard-coded. Tier 2 thresholds, Tier 3 enablement, abstain action, and synthesis thresholds are stored in the policy schema and synchronized from trained artifacts. Second, the specialist is not a general replacement for Tier 2. It is intentionally activated only on the calibrated uncertain slice, which makes the third stage both cheaper and more semantically focused.

3.2 System Components

Table 1 enumerates the principal components of the system and their responsibilities.

Component	Role and Key Design Choice
Tier 1 Regex Engine	Matches compiled regex rules against the full request surface (URL, headers, body). Uses a ReDoS-safe regex library with nested-quantifier detection and benign-holdout FP validation before any rule is installed.
Tier 2 Char-LSTM	Bidirectional LSTM (2 layers, hidden=128) over a 99-token printable-ASCII vocabulary. Calibrated with temperature scaling and binary-search threshold learning to achieve $\text{FNR} \leq 0.01$ and $\text{FPR} \leq 0.01$ on the validation set.
Tier 3 Specialist	MLP trained only on the tier-2 uncertain slice (3,344 records). Input is a 265-d concatenation of tier-2 hidden state (256-d), calibrated probability (1-d), gradient saliency (8-d), and structured HTTP features (15-d). Endpoint embedding (16-d) added for per-endpoint context. Focal BCE loss ($\gamma = 2.0$) addresses class imbalance.
Conformal Module	Mondrian split-conformal prediction. Per-endpoint empirical quantiles at $\alpha = 0.10$ yield four decision outcomes: $\Gamma = \{1\} \rightarrow \text{BLOCK}$, $\Gamma = \{0\} \rightarrow \text{ALLOW}$, $\Gamma = \{0, 1\} \rightarrow \text{ABSTAIN}$, $\Gamma = \emptyset \rightarrow \text{conservative BLOCK}$.
Regex Synthesizer	Extracts high-saliency character spans from Tier 3 forward passes. Filters candidate substrings by Shannon entropy (≥ 2.5 bits) and a deny-list of benign tokens. A sliding buffer tracks support counts; patterns meeting the minimum threshold are validated and atomically installed as new Tier 1 rules.
Policy Store	Profile CRUD with atomic file writes. Profiles encode Tier 2 thresholds, Tier 3 calibration mode, synthesizer parameters, and rule-safety settings. A bootstrap routine seeds the default profile from trained artifacts on first run.
Decision Logger	JSONL log with <code>fcntl</code> locking. Records tier, decision, confidence, per-tier latency, Tier 3 score, abstain flag, and prediction set. Separate schema for rule-install events.
Monitoring Dashboard	Streamlit application with 4 KPI metrics (total decisions, total rules, block rate, Tier-3 escalation rate over the last 5 minutes), a 50-row live decision table colourised by tier, and three Plotly analytics charts (Tier-3 escalation rate per minute, Tier-3 score distribution by live decision outcome, and cumulative rule count over time). A Profile Manager page exposes two seed profiles (default : calibrated mode, $\tau_{\text{low}} = 0.084$, $\tau_{\text{high}} = 0.184$, $\alpha = 0.10$; strict_prod : manual-override mode, $\tau_{\text{low}} = 0.05$, $\tau_{\text{high}} = 0.25$, abstain action BLOCK) with two configuration tabs: Routing (thresholds, Tier-3 toggle, abstain action, conformal α) and Safety (fail-open mode, FP threshold, ReDoS timeout, install mode).

Table 1: Principal system components and their design roles.

3.3 System Implementation

Figure 2 summarizes the offline pipeline. The project preprocesses the CSIC traffic into a unified JSONL format, holds out benign data for regex validation, trains Tier 2, calibrates Tier 2 thresholds, builds out-of-fold (OOF) Tier 2 predictions, trains the specialist on the uncertain slice, calibrates conformal abstention, and finally synchronizes the effective thresholds back into the runtime profile.

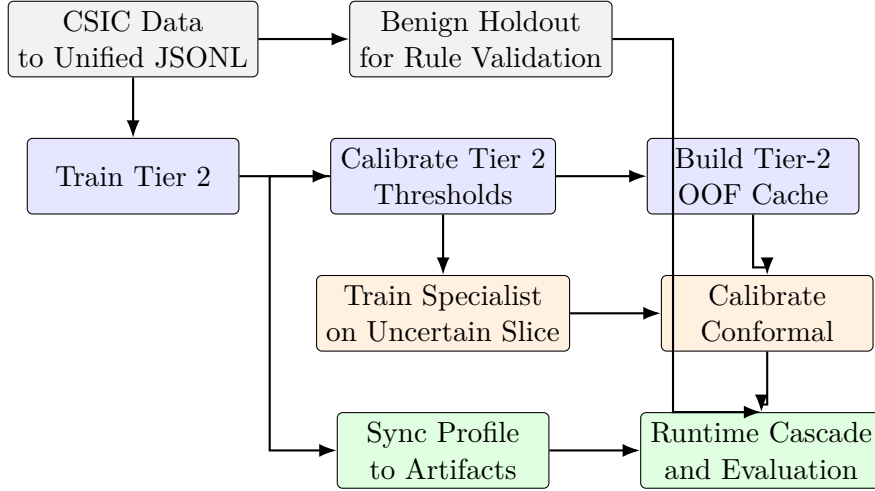


Figure 2: Offline training, calibration, and profile-synchronization flow.

The pipeline produces eight model artifacts that the runtime loads at startup: `ml_waf.pt` (Tier 2 weights), `ml_config.json` (architecture and calibrated thresholds), `calibration_cache.npz` (validation logits for threshold recomputation), `tier2_oof_train.npz` (uncertain-slice training set for Tier 3), `specialist.pt` (Tier 3 weights), `specialist_config.json` (endpoint map and feature statistics), `specialist_conformal.json` (per-endpoint quantiles), and `specialist_oof_pred.npz` (OOF predictions used during conformal calibration).

The specialist-era implementation also required a codebase cleanup pass. Stale anomaly-era artifacts and helpers were removed, specialist terminology replaced the remaining obsolete names, and the source tree was regrouped so directories stayed small and modules remained under the repository’s 300-line size limit. The final code validation status is summarized in Table 2.

Check	Outcome
Repo-wide Python compilation	Passed for <code>train</code> , <code>waf</code> , <code>eval</code> , <code>dashboard</code> , and <code>tests</code> .
Non-integration regression suite	350 passed (prior run reported 346 passed, 4 skipped; a path-default fix resolved the skipped tests).
Source file size rule	All production Python files in <code>waf</code> , <code>train</code> , <code>eval</code> , and <code>dashboard</code> are below 300 lines.
Directory grouping rule	Source directories were regrouped to satisfy the at-most-three-files-per-directory constraint; model-artifact storage remains separate in <code>waf/models</code> .

Table 2: Implementation validation completed.

3.4 System Operations

At runtime a single HTTP request passes through the following sequence:

1. **Tier 1 check.** The WAF builds a search surface by concatenating the URL, headers, and body into a single string. Each compiled regex rule is applied in order; the first match returns a BLOCK decision immediately with confidence = 1.0.
2. **Tier 2 evaluation.** If no rule fires, the request text is tokenized to a 99-token printable-ASCII representation (max length 512 characters) and fed through the BiLSTM. A temperature-scaled sigmoid converts the output logit to a calibrated probability p .
3. **Routing decision.** The router compares p against the profile’s thresholds: $p < \tau_{\text{low}}$ yields ALLOW; $p > \tau_{\text{high}}$ yields BLOCK; $\tau_{\text{low}} \leq p \leq \tau_{\text{high}}$ escalates to Tier 3. Calibrated thresholds on the CSIC training split are $\tau_{\text{low}} = 0.084$ and $\tau_{\text{high}} = 0.184$, giving a narrow uncertain band in which Tier 3 is invoked.
4. **Tier 3 scoring.** The specialist extracts the tier-2 hidden state, computes input-gradient saliency (top-8 magnitude positions), assembles structured HTTP features (15-d), and looks up the endpoint embedding. A forward pass through the specialist MLP produces a logit from which the conformal module derives the prediction set Γ_α .
5. **Conformal decision.** The prediction set determines the final outcome as described in Table 1. When $\Gamma = \{0, 1\}$ (abstain), the profile’s `abstain_action` setting determines whether to ALLOW or BLOCK the request conservatively.
6. **Regex synthesis.** When Tier 3 produces a confident BLOCK whose score exceeds the synthesis threshold, the saliency map is passed to the synthesizer. After entropy filtering, deny-list filtering, and support-count checking, eligible patterns are validated against the benign holdout and atomically appended to the live rules file, creating a new Tier 1 rule for future cheap detection.
7. **Logging.** Every decision is appended to the JSONL decision log with tier, decision, confidence, per-tier latency breakdowns, and Tier 3 metadata. Rule-install events are written to a separate install log.

4 Experiments and Results

4.1 Tier Benchmark

Table 3 reports accuracy, precision, recall, F1, and FPR for each tier and for the full cascade on the CSIC 2010 test split ($n_{\text{pos}} = 3705$ attacks, $n_{\text{neg}} = 10856$ benign, $n_{\text{total}} = 14561$).

Tier	Acc	Prec	Recall	F1	FPR	FNR
Tier 1 (regex only)	0.748	1.000	0.009	0.017	0.000	0.991
Tier 2 (LSTM)	0.990	0.998	0.961	0.979	0.001	0.039
Tier 2 router policy	0.984	0.967	0.972	0.970	0.011	0.028
Cascade (T1+T2+T3)	0.986	0.966	0.978	0.972	0.012	0.022

Table 3: Tier benchmark on the CSIC 2010 test split.

Several findings merit discussion. Tier 1 achieves perfect precision (no false positives) but near-zero recall (0.9%), confirming that the 25 CRS-style regex rules cover only a narrow slice of CSIC attack patterns. The CSIC 2010 dataset encodes attacks primarily as anomalous HTTP parameter distributions rather than recognisable keywords, so signature-only defences are structurally insufficient on this corpus. Tier 2 alone delivers strong performance ($F1 = 0.979$, $FPR = 0.001$); the router policy trades a small precision decrease for a 1.1 pp recall improvement by lowering the effective block threshold. The full cascade recovers a further 0.54 pp in recall over the router policy (from 97.22% to 97.76%) while maintaining similar precision, showing that the Tier 3 specialist provides a modest but consistent improvement on the uncertain band.

4.2 Adversarial Robustness

Table 4 shows detection rates under six mutation strategies applied to 100 sampled attack records, broken down by tier. The *baseline* row reflects unmodified attacks; the remaining rows apply transformations commonly used to evade signature-based defences ($n = 100$ attacks per mutation).

Mutation	Tier 1	Tier 2	Cascade (T1+T2+T3)
Baseline (no mutation)	0.00	0.92	0.96
SQL comment insertion	0.00	1.00	1.00
Double percent-encoding	0.00	1.00	1.00
Keyword null-byte split	0.00	0.92	0.96
Null-byte path suffix	0.00	0.85	0.93
Unicode full-width encoding	0.00	0.87	0.87

Table 4: Detection rates under adversarial mutations across all three tiers (100 sampled CSIC attacks per mutation).

Two findings stand out. First, Tier 1 regex detection is zero across all mutations, including the unmodified baseline. The CSIC 2010 dataset encodes attacks as HTTP parameter anomalies rather than keyword-injection patterns matching the CRS-style signatures in `live.conf`; this confirms that signature-only defences are insufficient for this traffic profile and motivates the ML tiers. Second, the full cascade consistently outperforms Tier 2 alone: the specialist recovers 4–8 additional detections per 100 on the baseline, keyword null-byte, and null-byte path suffix mutations, while offering no regression on the others. The unicode full-width mutation is the hardest case, as it distorts the character-level input distribution that both Tier 2 and the specialist were trained on.

4.3 ML-Tier Results

The specialist model is evaluated on the 443-sample uncertain slice ($\tau_{\text{low}} \leq p < \tau_{\text{high}}$) of the CSIC 2010 test split ($n_{\text{pos}} = 65$, $n_{\text{neg}} = 378$; 87% benign). Table 5 reports decision quality and conformal diagnostics for this slice.

Metric	Value
Precision (decided cases)	0.870
Recall	0.308
F1	0.455
FPR	0.008
FNR	0.692
Abstain rate ($\alpha = 0.10$)	0.140
Empirical set coverage	0.916
AUC (uncertain slice)	0.656
$n_{\text{pos}} / n_{\text{neg}} / n_{\text{total}}$	65 / 378 / 443

Table 5: Tier 3 specialist metrics on the uncertain slice of the CSIC 2010 test split ($\tau_{\text{low}} = 0.084$, $\tau_{\text{high}} = 0.184$). Precision, recall, FPR, and FNR are computed over decided (non-abstain) cases only.

Several observations merit discussion. First, the specialist achieves 87.0 % precision on decided cases with a 14.0 % abstain rate, and the empirical conformal set coverage of 91.6 % exceeds the $1 - \alpha = 0.90$ target, confirming that the Mondrian calibration holds on the held-out test slice. Second, recall is constrained at 30.8 %: the uncertain band is overwhelmingly benign (87 %), so the model withholds judgement on ambiguous positives rather than issuing low-confidence blocks; those undecided positives fall through to the abstain-action (ALLOW) fallback. Third, the slice-level AUC of 0.656 is modest but meaningful — the specialist must discriminate among requests that the Tier 2 gate already found ambiguous, an inherently harder sub-problem than full-dataset separation (Tier 2 AUC = 0.999). Together these metrics confirm the intended design: the specialist reduces false negatives from the uncertain band when it is confident, and defers otherwise. The full cascade consequently recovers a 0.54 pp recall improvement over the Tier 2 router policy (Table 3) at a negligible FPR cost of +0.03 pp.

5 Conclusion

This project delivers an uncertainty-routed three-tier WAF that combines deterministic rules, a calibrated Tier 2 neural classifier, and a specialist Tier 3 model with conformal abstention. The main architectural contribution is not simply adding a third model, but constraining each stage to a role it can perform well: signatures for known patterns, a fast neural gate for the majority of requests, and a specialist only for ambiguous cases. The regex-synthesis feedback loop further differentiates the system from static detection pipelines by converting runtime evidence into new deterministic rules, gradually reducing the fraction of traffic that needs ML evaluation at all.

Limitations. Several limitations are worth acknowledging. First, the Tier 2 backbone is a character-level BiLSTM, a model family that predates the transformer era; more expressive attention-based encoders might improve the calibration quality and reduce the uncertain-band width, at the cost of higher per-request latency. Second, evaluation is confined to the CSIC 2010 dataset; cross-dataset generalisation to modern HTTP traffic has not been demonstrated, and the conformal coverage guarantee is only valid under the exchangeability assumption that holds within a fixed dataset split. Third, the per-endpoint conformal calibration degrades gracefully but not provably when an endpoint has fewer than roughly 30 calibration samples; the system falls back to a global

quantile in those cases. Finally, the Profile Manager in the monitoring dashboard is a demo implementation backed by in-memory session state; the full control-plane profile CRUD specified in the design documents has not yet been deployed.

Future Work. Three directions could extend this work meaningfully. First, replacing the CharLSTM with a lightweight transformer encoder pre-trained on HTTP traffic would allow comparison of escalation rates and latency tradeoffs on a more expressive backbone, with the uncertainty-routing logic unchanged. Second, extending the conformal module to multi-class attack-type prediction (SQL injection, XSS, path traversal, and benign as separate classes) rather than binary block/allow would enable finer-grained routing and more targeted regex synthesis. Third, completing the deployment of the control-plane profile manager would allow operators to adjust thresholds, toggle Tier 3, and review synthesis candidates through the dashboard rather than through configuration files, closing the gap between the system’s theoretical configurability and its practical operator interface.

References

- [1] Abhinav B V, Akash Bhat, Abhirup MVNS, Clara Kanmani A, and Adithya D. Shetty. Dynamic threat detection and mitigation using ai-infused firewalls. In *2025 13th International Symposium on Digital Forensics and Security (ISDFS)*, 2025. DOI: <https://doi.org/10.1109/ISDFS65363.2025.11011964>.
- [2] Muhammad Bangkit Dwi Cahyono and Muhammad Zuhri Catur Candra. Machine learning module in a web application firewall for multi-label web attacks detection. In *2025 IEEE International Conference on Data and Software Engineering (ICoDSE)*, 2025. DOI: <https://doi.org/10.1109/ICoDSE68111.2025.11351532>.
- [3] Yasin Carkci, Alperen Sayar, Seyit Ertugrul, Gorkem Demircan, Asli Karabulut, and Boran Ertugrul. Dark web-driven threat intelligence and machine learning-powered network anomaly detection for automated firewall rule management. In *2025 International Conference on Artificial Intelligence Security and Governance (ICAISG)*, 2025. DOI: <https://doi.org/10.1109/ICAISG68699.2025.11452145>.
- [4] Cristian Chindrus and Constantin F. Caruntu. Improving waf performance with advanced ml models: From rnn to gru and lstm. In *2025 29th International Conference on System Theory, Control and Computing (ICSTCC)*, 2025. DOI: <https://doi.org/10.1109/ICSTCC66753.2025.11240342>.
- [5] Harsika Diksha and Tushar Gautam. Ml based intrusion detection system using nlp. In *2025 IEEE Space, Aerospace and Defence Conference (SPACE)*, 2025. DOI: <https://doi.org/10.1109/SPACE65882.2025.11170876>.
- [6] Shiming He, Ying Zhang, Diqing Liang, and Pradip Kumar Sharma. An unsupervised malicious web request detection based on transformer and contrastive learning. *IEEE Transactions on Network and Service Management*, 2025. DOI: <https://doi.org/10.1109/TNSM.2025.3563089>.
- [7] Raghda Hriez, Ali Hadi, Akram Barakat, Jalal S. Omer, Qabas Ahmad, and Ayat Droos. Anomaly detector for http protocol. In *2025 International Conference on Electrical, Com-*

- munication and Computer Engineering (ICECCE)*, 2025. DOI: <https://doi.org/10.1109/ICECCE67514.2025.11257900>.
- [8] Abrar Ikramaputra, Amang Sudarsono, and Norma Ningsih. Enhancing web application firewall with ensemble machine learning to detect sql injection attacks. In *2025 International Electronics Symposium (IES)*, 2025. DOI: <https://doi.org/10.1109/IES67184.2025.11160726>.
 - [9] Mamdouh Muhammad, Sushmetha Arumugam, and Loui Al Sardy. Ai-based anomaly detection for enhanced cybersecurity in iot networks. In *2025 9th Cyber Security in Networking Conference (CSNet)*, 2025. DOI: <https://doi.org/10.1109/CSNet67572.2025.11288241>.
 - [10] Manh Tien Anh Nguyen, Van Tong, Sondes Bannour Souihi, and Sami Souihi. Zero trust: Deep learning and nlp for http anomaly detection in ids. *IEEE Journal on Selected Areas in Communications*, 2025. DOI: <https://doi.org/10.1109/JSAC.2025.3560040>.
 - [11] Praval Panwar. Anomaly detection in web applications: A one-class svm based firewall for http request monitoring. In *2025 IEEE 3rd International Conference on Control, Electronics and Computer Technology (ICCECT)*, 2025. DOI: <https://doi.org/10.1109/ICCECT64621.2025.11339633>.
 - [12] T. N. V. S. Praveen, Matta Durga Sravani, Ummadi Sruthi, and Bhogireddy Rupa Sri. An intelligent deep learning model for xss attack detection using enhanced lstm. In *2025 International Conference on Innovations in Intelligent Systems: Advancements in Computing, Communication, and Cybersecurity (ISAC3)*, 2025. DOI: <https://doi.org/10.1109/ISAC364032.2025.11156304>.
 - [13] Khoerina Sa'adah, Rayhan Ramdhany Hanaputra, Girinoto, and Setiyo Cahyono. A deep learning approach to detect cross-site scripting attack as a web application firewall. In *2024 International Conference on Information Technology and Computing (ICITCOM)*, 2024. DOI: <https://doi.org/10.1109/ICITCOM62788.2024.10762471>.
 - [14] Yaxin Shi, Guang Yang, Xiao Wang, Qianqian Yu, Ying Feng, and Ang Liu. A review of deep learning based anomaly detection. *Neurocomputing*, 2026. DOI: <https://doi.org/10.1016/j.neucom.2025.132383>.
 - [15] Veeramani Sonai and Hari Kumar A. Enhancing network security by integrating machine learning algorithms with firewall systems to detect cyber attacks. In *2025 IEEE Silchar Subsection Conference (SILCON)*, 2025. DOI: <https://doi.org/10.1109/SILCON67893.2025.11327363>.
 - [16] G. Thanigaivel and A. Yeswanth. Cybersentinel: Machine learning-driven attack severity prediction & threat intelligence using unsw-nb15 dataset. In *2025 2nd International Conference on Research Methodologies in Knowledge Management, Artificial Intelligence and Telecommunication Engineering (RMKMATE)*, 2025. DOI: <https://doi.org/10.1109/RMKMATE64874.2025.11042779>.
 - [17] Nathalie Wehbe, Hyame Assem Alameddine, and Chadi Assi. Http/2 dos attacks in 5g networks: Impact analysis and anomaly detection. *IEEE Transactions on Mobile Computing*, 2026. DOI: <https://doi.org/10.1109/TMC.2026.3657143>.
 - [18] Yijia Xu, Qiang Zhang, Huaxin Deng, Zhonglin Liu, Cheng Yang, and Yong Fang. Unknown web attack threat detection based on large language model. *Applied Soft Computing*, 2025. DOI: <https://doi.org/10.1016/j.asoc.2025.112905>.

- [19] Lulu Zhou and Dazhi Zhao. Design and implementation of a network traffic classification system based on machine learning. In *Procedia Computer Science*, 2025. DOI: <https://doi.org/10.1016/j.procs.2025.04.050>.